EXECUTIVE SUMMARY

SecureBank Financial: SecureMobile Banking Platform — Quantitative Cybersecurity Risk Assessment

Assessment: Lab 3b — Advanced Cybersecurity Risk Quantification
Prepared by: Lead GRC Analyst
Organisation: SecureBank Financial
Audience: Chief Information Security Officer (CISO) and Chief Financial Officer (CFO)
Currency: United States Dollars (USD)

1. Overview

SecureBank Financial conducted a quantitative cybersecurity risk assessment of its SecureMobile banking platform following a penetration test and vulnerability assessment that identified three critical security weaknesses: API authentication bypass, database injection, and session hijacking. These vulnerabilities present potential threats to the confidentiality, integrity, and availability of banking services, customer information, and financial transactions.

SecureMobile supports 500,000 active customers and processes approximately 50,000 transactions daily, with an average transaction value of $2,500. Given the platform's financial significance and the sensitivity of customer information, effective risk treatment is essential to reducing the likelihood and financial consequences of a successful attack.

The purpose of this assessment was to quantify the potential financial exposure associated with the identified vulnerabilities, prioritise the risks, evaluate the proposed security controls, and recommend cost-effective treatments. The analysis applies the quantitative risk formulas presented in the GRC study guide, including Single Loss Expectancy (SLE), Annualised Loss Expectancy (ALE), residual risk, risk reduction, return on investment (ROI), and payback period.

2. Key Risk Assessment Findings

The analysis estimates a combined annual loss exposure of **$35,000,000** across the three identified risk scenarios. Database injection represents the largest modelled financial

exposure, with an estimated single-event loss of $125,000,000 and an ALE of $31,250,000. This scenario assumes that all 500,000 customer records could be affected and that the estimated regulatory and notification cost of $250 applies to every affected record.

Session hijacking has the highest supplied exploit probability at 40%, with a modelled ALE of $3,000,000. API authentication bypass has a supplied exploit probability of 15% and a modelled ALE of $750,000. Although the API scenario has the lowest ALE of the three, unauthorised fund transfers could still result in substantial financial and operational consequences.

The following table summarises the quantified risks.

Vulnerability	Single Loss Expectancy (SLE)	Assumed Annual Probability	Modelled ALE	Priority
API authentication bypass	$5,000,000	15%	$750,000	High
Database injection	$125,000,000	25%	$31,250,000	Critical
Session hijacking	$7,500,000	40%	$3,000,000	High
Total	—	—	**$35,000,000**	—

The calculations use the study-guide formula:

ALE = SLE × ARO

The supplied exploit probabilities do not specify a time period or represent confirmed incident frequencies. For this simplified assessment, they are interpreted as assumed annual probabilities of at least one loss event and used as annual rate proxies under a one-loss-event-per-year approximation. Consequently, the figures should be treated as modelled annual loss exposure estimates, not precise forecasts of future losses. Actual incident frequency, historical fraud data, recoveries, and validated loss estimates would be needed to refine the results.

3. Security Control Evaluation

Three proposed controls were evaluated: an Advanced API Security Gateway, a Web Application Firewall (WAF), and Multi-Factor Authentication (MFA) enhancement. Each control was assigned to one primary risk scenario to prevent double-counting the same risk reduction.

The study-guide formula for residual risk is:

New Risk = Current ALE × (1 − Control Effectiveness)

Risk reduction is calculated as the difference between the original ALE and the residual ALE after applying the control's stated effectiveness.

The results indicate that the API Security Gateway could reduce the modelled API-related ALE by $675,000 annually, the WAF could reduce the database-injection-related ALE by $23,437,500 annually, and MFA enhancement could reduce the session-hijacking-related ALE by $2,850,000 annually.

Proposed Control	Initial Investment	Annual Maintenance	Modelled Annual Risk Reduction	Residual ALE
Advanced API Security Gateway	$350,000	$50,000	$675,000	$75,000
Web Application Firewall (WAF)	$150,000	$25,000	$23,437,500	$7,812,500
MFA enhancement	$200,000	$30,000	$2,850,000	$150,000
Total	**$700,000**	**$105,000/year**	**$26,962,500/year**	**$8,037,500**

The combined control investment therefore represents an initial expenditure of $700,000 and annual maintenance expenditure of $105,000. Assuming all three controls operate at their stated effectiveness levels, the model estimates a reduction in annual loss exposure from $35,000,000 to $8,037,500. This represents a modelled annual risk reduction of approximately 77.0%.

4. Financial Justification and Return on Investment

A three-year evaluation period was selected to assess the proposed investments. Total lifecycle cost includes the initial implementation expenditure and three years of maintenance.

The ROI formula specified in the study guide is:

ROI = [(Benefit − Cost) ÷ Cost] × 100

For this assessment, the benefit is the modelled gross expected loss avoided over three years, calculated by multiplying annual risk reduction by three. The cost is initial implementation expenditure plus three years of maintenance. The calculation does not include discounting, inflation, or changes in control performance during the evaluation period.

Control	Three-Year Lifecycle Cost	Three-Year Modelled Benefit	Three-Year ROI	Estimated Payback
Advanced API Security Gateway	$500,000	$2,025,000	305.0%	6.72 months

Web Application Firewall (WAF)	$225,000	$70,312,500	31,150.0%	0.08 months
MFA enhancement	$290,000	$8,550,000	2,848.3%	0.85 months
Combined portfolio	**$1,015,000**	**$80,887,500**	**7,869.2%**	—

Payback is estimated by dividing the initial investment by annual risk reduction less annual maintenance cost. These payback periods are simplified estimates based on modelled expected loss avoidance, not guaranteed cash savings or realised revenue.

The WAF produces the highest modelled ROI because the database-injection scenario carries a disproportionately large assumed loss. This result should not be interpreted as proof that the WAF alone will prevent database breaches or eliminate the stated exposure. The assumed per-record cost, number of records affected, and control effectiveness must be validated before management relies on the ROI figures for an actual investment decision.

5. Recommendations and Risk Treatment Priorities

The assessment recommends treating the database-injection risk as the highest financial priority while addressing all three vulnerabilities through a coordinated security programme.

Immediate actions — first 30 days: SecureBank should validate the database exposure assumptions, restrict unnecessary database access, review privileged access, investigate the vulnerable application components, and begin remediation of unsafe database queries. Appropriate technical measures include parameterised queries, secure input handling, least-privilege database permissions, and security testing. The security team should also review API authorisation logic, transaction limits, monitoring, and session-management weaknesses.

Short-term implementation — within 90 days: Implement and test the proposed WAF, Advanced API Security Gateway, and MFA enhancement according to an approved deployment plan. The API gateway should be configured to support strong authentication, authorisation, rate limiting, and transaction-related monitoring. WAF rules should be tested against the identified application weaknesses and monitored for false positives and bypasses. MFA should be combined with secure session-token handling, session revocation, risk-based monitoring, and protections against account takeover.

Long-term strategy — within one year: Establish continuous vulnerability management, periodic penetration testing, control-effectiveness reviews, incident-response exercises, and ongoing quantitative risk reporting. Management should compare actual security incidents, verified financial losses, remediation progress, and operational performance against the assumptions in this assessment. Control effectiveness should be reassessed using testing evidence before residual-risk estimates are accepted.

The proposed implementation dates are planning recommendations for this exercise; they are not confirmed organisational commitments.

6. Limitations and Management Considerations

The assessment is based on the scenario data supplied in the laboratory brief. It does not include verified historical incident frequencies, probability distributions for loss severity, recoveries, insurance, indirect reputational effects, customer attrition, business interruption, or independently validated control effectiveness.

The database-injection SLE is especially sensitive to the assumption that all 500,000 records are affected at $250 per record. The API and session-hijacking estimates also depend on the stated maximum incident loss and account-loss assumptions. In addition, the risk-reduction model assumes that each control achieves its stated effectiveness against its assigned risk. Actual effectiveness may differ, and some controls may require additional safeguards or remediation measures to achieve the intended outcome.

The three-year ROI model assumes that the annual risk reduction remains constant throughout the evaluation period and does not discount future benefits. The model therefore supports comparative planning and budget discussion but should not replace a validated business case based on operational evidence.

7. Conclusion

The SecureMobile assessment demonstrates that the identified vulnerabilities could expose SecureBank Financial to significant financial loss. Under the assumptions used in this model, the combined annual loss exposure is estimated at $35,000,000, with database injection accounting for the largest share.

Implementing the three proposed security controls is estimated to reduce annual loss exposure by $26,962,500, leaving residual exposure of $8,037,500. The combined initial investment is $700,000, with annual maintenance of $105,000. Over three years, the model estimates a total lifecycle cost of $1,015,000 and a portfolio ROI of 7,869.2%.

The recommended management decision is to prioritise database-injection remediation and the supporting WAF deployment, while proceeding with the API Security Gateway and MFA enhancement through a coordinated risk-treatment programme. Approval should be conditional on validating the underlying financial assumptions, confirming the controls' applicability and effectiveness through testing, assigning accountable control owners, and reporting residual risk and implementation progress to the CISO and CFO.

This approach enables SecureBank Financial to make evidence-informed security investment decisions, improve the protection of customer information and financial transactions, and establish a measurable process for ongoing cybersecurity risk management.